Vulnerability Assessment and Penetration Testing (VAPT) Using Open-Source Security Tools

Name: Mukkeri Pooja

Target Target Machine: Metasploitable 3 (Vulnerable Virtual Machine)

IP Address: 192.168.1.10

Attacker Machine: Kali Linux / Windows Scanning Machine

Tools Used: Nmap, Wireshark, OpenVAS, Nikto

Version: Nmap 7.98

Scan Date: 1 February 2026

THEORETICAL KNOWLEDGE

1. Understanding Security Assessment

Objective :

The objective of *Security Assessment* is to evaluate computer systems, networks, and applications in order to identify vulnerabilities and security weaknesses using *free or open-source tools instead of paid tools*. It helps organizations understand their security posture and implement appropriate security controls to protect their digital assets from cyber threats.

Explanation :

A *Security Assessment* is a systematic process used to identify, analyze, and evaluate security risks present in an organization's IT infrastructure. The purpose is to find vulnerabilities before malicious attackers exploit them.

Security assessments evaluate several components such as:

- Network infrastructure
- Web applications
- Operating systems
- Databases
- System configurations

- User authentication mechanisms

The process follows security frameworks and guidelines that ensure standardized evaluation procedures.

Common frameworks include :

- *NIST Cybersecurity Framework*
- *ISO 27001 Information Security Standard*
- *OWASP Security Testing Guidelines*

These frameworks provide best practices for identifying and mitigating security risks.

Types of Security Testing :

Security testing comes in many flavors, each designed to detect specific types of security weaknesses in your security posture. The three main ones you'll encounter are:

1.1) Vulnerability Assessment

1.2) Penetration Testing

1.3) Compliance Testing

1.1 Vulnerability Assessment :

A Vulnerability Assessment is the process of scanning systems, networks, and applications for security weaknesses. It's the process of digging and finding security flaws, and then reporting what has been found and how critical each issue is. Note that no hacking or exploitation of the discovered flaws occurs.

A list of security issues, each with its associated severity rating. Common security issues include :

- Outdated software versions

- Weak authentication schemes

- Server configuration problems

- Open network ports

- Missing security patches

Tools often used :

- OpenVAS (Open Vulnerability Assessment System): This is an open-source security scanner with an extensive list of known security vulnerabilities.

- Nikto: This is a web server scanner used to identify security problems in web servers and applications.

Example :

Suppose the security scanner discovers an outdated version of the Apache web server. The results would include:

- CVE ID: This refers to the Common Vulnerabilities and Exposures ID assigned to the security flaw.

- Vulnerability description: This refers to the security weakness discovered in the system or network.

- Risk level: This refers to the criticality of the security flaw discovered.

- Patch or update: This refers to the recommended fix or update for the security flaw.

1.2 Penetration Testing :

Explanation :

Penetration testing, also known as pentesting, is a sophisticated security test in which experts mimic a real-life cyber attack to identify vulnerabilities. In penetration testing, experts try to find ways to gain entry into a computer system, determine what information an attacker could gain access to, and what kind of damage they could cause. This is done to identify vulnerabilities in a computer system and assess the level of preparedness of an organization in responding to cyber attacks.

Tools Used :

Penetration testing usually requires tools that are available in Kali Linux.

Nmap

Nmap is a tool that is utilized in penetration testing to scan a computer network and find hosts, ports, and services that are running. An instance of this is as follows:

nmap -sV 192.168.29.1

This is a command that is issued to identify what kind of services are running on a computer with the IP address 192.168.29.1

Metasploit Framework

Metasploit is a penetration tool that is utilized to exploit vulnerabilities in a computer system in order to gain entry into it. It is a tool that is utilized to exploit vulnerabilities in a computer system in order to gain entry into it. It is a tool that is utilized to assess computer security defenses.

Compliance Testing

Explanation :

Compliance testing is a security test that is done to ensure that an organization is in compliance with various security regulations and policies. It is done to ensure that computer systems are in compliance

with security guidelines and policies. It is done to ensure that computer systems are in compliance with security guidelines and policies. Compliance testing is done to ensure that computer systems are in compliance with security guidelines and policies. Compliance testing is done to ensure that computer systems are in compliance with security guidelines and policies.

Examples of Compliance Standards

- CIS Benchmarks
- GDPR
- HIPAA
- ISO 27001

2. VAPT Methodology

Objective The objective of VAPT is to provide a comprehensive and well-structured guide for identifying, analyzing, and exploiting vulnerabilities in a system to improve overall system security.

Explanation VAPT is a comprehensive approach to two critical security testing processes:

- Vulnerability Assessment: This is a process for identifying vulnerabilities in a system.
- Penetration Testing: This is a process for exploiting vulnerabilities in a system to assess their impact.

These two processes are integrated to provide a comprehensive view of system security.

Phases of VAPT VAPT consists of a number of well-structured phases :

2.1. Planning Phase : In this phase, the objective of the security test is determined. This involves:

- Identifying systems to test
- Identifying methods to use in testing
- Identifying boundaries for testing
- Seeking legal clearance for testing

Dradis Community Edition (CE) is a tool that helps in organizing test documentation.

2.2.Discovery Phase : In this phase, data is collected about a system under test. This involves:

- Scanning networks
- Scanning services
- Scanning applications in use
- Web application scanning

Tools used:

- Nmap – to identify hosts and open ports. Example: nmap -A 192.168.29.1
- OWASP ZAP – an open-source web application security scanner to identify vulnerabilities in web applications. Vulnerabilities detected: SQL Injection Cross Site Scripting Authentication vulnerabilities

2.3.Attack Phase : In this phase, attackers try to exploit vulnerabilities detected in the system. Tools used:

- Metasploit Framework – to launch attacks against vulnerable targets. The objective is to test whether vulnerabilities are successfully exploited.

2.4.Reporting Phase : The final phase is to generate a report for the assessment done. The report consists of:

- Description of vulnerabilities detected
- CVSS risk score for vulnerabilities
- Screenshots of proof of concept for vulnerabilities detected
- Suggested steps for exploitation

How to Learn VAPT For a beginner, hands-on experience is possible using:

- Vulnerable virtual machines
- Capture-the-Flag games
- Web vulnerability labs

The OWASP Web Security Testing Framework provides guidelines for web security testing in detail.

3.Security Standards and Compliance

Objective :

Ensure that all organizations adhere to established guidelines to safeguard information systems and sensitive information.

Standards :

There are various security standards established globally that provide guidelines on how to implement information security best practices.

GDPR (General Data Protection Regulation) A European-based regulation that seeks to protect personal data and uphold individual privacy. Key requirements:

- Safeguard personal data
- Report data breaches
- Establish robust data protection policies

HIPAA (Health Insurance Portability and Accountability Act)

A regulation that seeks to protect health information. Key responsibilities of a healthcare organization:

- Secure storage of medical information
- Regulate access to patient information
- Encrypt information

ISO 27001

A security standard that provides guidelines on how to implement an Information Security Management System (ISMS) to safeguard organizational information assets.

How to Learn Security Standards A key resource to learn about security vulnerabilities is the OWASP Top 10. Key security vulnerabilities highlighted include:

- SQL Injection
- Cross-Site Scripting
- Broken Authentication
- Security Misconfiguration
- Sensitive Data Exposure

4. Risk Assessment Basics

Objective :

The objective of Risk Assessment is to identify vulnerabilities and assess their potential impact on systems and organizations. Explanation Risk is determined by two main factors:

- **Likelihood**: The likelihood of a vulnerability being exploited.
- **Impact**: The potential impact of a vulnerability being exploited. CVSS Calculator The Common Vulnerability Scoring System (CVSS) is a system for calculating vulnerability severity. CVSS scores are categorized into:

scores	severity
0-3.9	Low
4-6.9	Medium
7-8.9	High
9-10	Critical

- Critical The NVD CVSS Calculator is a tool for calculating CVSS scores using vulnerability characteristics.

Risk Matrix :

A Risk Matrix is a method for classifying risks by likelihood and impact. Explanation For instance:

likelihood	impact	Risk Level
High	High	Critical
Medium	High	High
Low	Medium	Medium

5. Common Vulnerabilities

Objective :

The objective of this section is to understand common vulnerabilities present in networks and web applications so security professionals can effectively identify them.

Network Vulnerabilities :

Network vulnerabilities are identified by misconfigured networks or services not running securely.

Common Network Vulnerabilities :

- Open Ports
- Weak Firewall Settings
- Default Passwords
- Outdated Network Services

The Nmap tool is the most commonly used tool for identifying vulnerabilities.

Example Command :

nmap -sS 192.168.29.1

Web Application Vulnerabilities :

Web applications are often found to have hollow spots, allowing attackers to penetrate them.

Common Web Application Vulnerabilities :

- **SQL Injection :** allowing attackers to access sensitive data
- **Cross-Site Scripting :** allowing attackers to execute malicious scripts

How to Learn About Vulnerabilities

There are many platforms for learning about vulnerabilities, including:

- **OWASP Juice Shop :** a web application designed to be vulnerable for security testing
- **Metasploitable :** an intentionally vulnerable VM for practice
- **VulnHub :** a platform providing vulnerable machines for download

6. Documentation Fundamentals

Objective :

The objective of this section is to learn about documentation, its importance, and its use in identifying vulnerabilities, testing, and remediation steps.

Explanation :

What should be included in security documents:

- Description of vulnerabilities
- Evidence and screenshots
- Risk severity
- Recommendations for fixing issues

This will help security teams understand the content of the document.

Tools for Documentation

- **Dradis Community Edition:** This is a collaborative reporting tool used by testers.
- **CherryTree:** This is an application note-taking tool used to document technical details during security assessment.

How to Learn Documentation For those who are new to this topic, there are free penetration testing report templates available on GitHub. These templates will help you learn how to create reports using sections such as:

- Executive Summary
- Technical Findings
- Risk Assessment
- Remediation Recommendations
- Installing Kali Linux
- Setting up Metasploitable
- Running OpenVAS scans
- Using Nmap
- Vulnerability scans
- Security assessment report This will help you complete your assignment completely.

PRACTICAL APPLICATION

1. Setup Testing Environment

Objective

The objective behind setting up a testing environment is to create a *safe laboratory for cybersecurity testing* where vulnerabilities can be analyzed.

The purpose behind creating a virtual lab is to *scan, test, and exploit vulnerabilities legally*.

Tools Required

The tools required for the practical application are:

- *Kali Linux* - a penetration testing operating system
- *Metasploitable 3* - a deliberately vulnerable virtual machine
- *VirtualBox* - a virtualization tool for running multiple operating systems on a single computer.

Step 1: Install VirtualBox

The first step is to install VirtualBox on the computer. VirtualBox is a powerful tool for running multiple operating systems on a single computer.

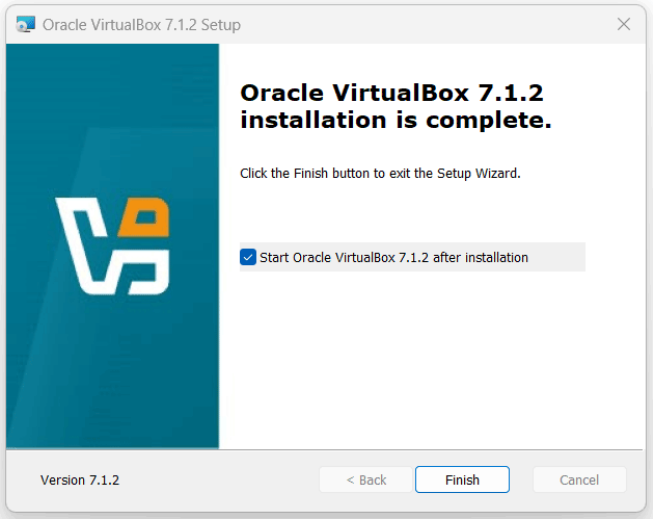
Steps:

1. Download VirtualBox from the official website.

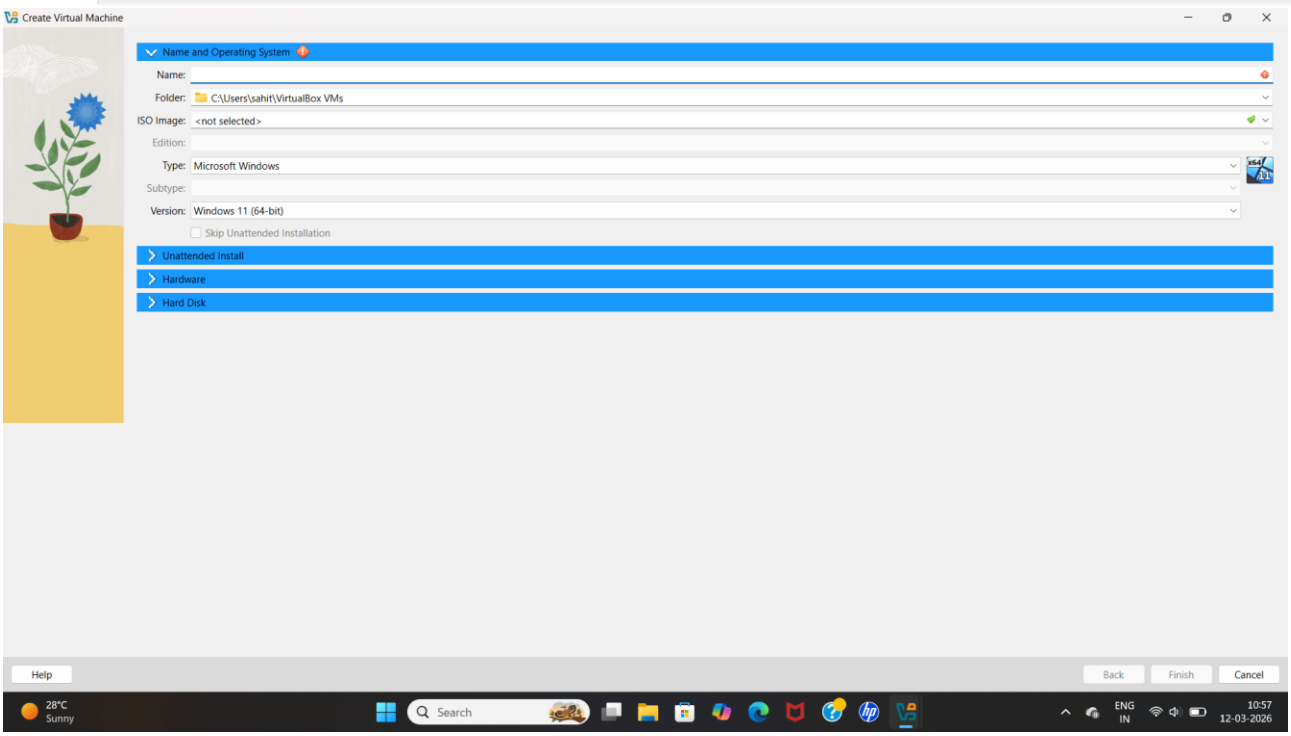
2. Install the downloaded VirtualBox on the computer.

3. Launch VirtualBox after installing it.

- **VirtualBox installation screen**



- **VirtualBox dashboard screen**



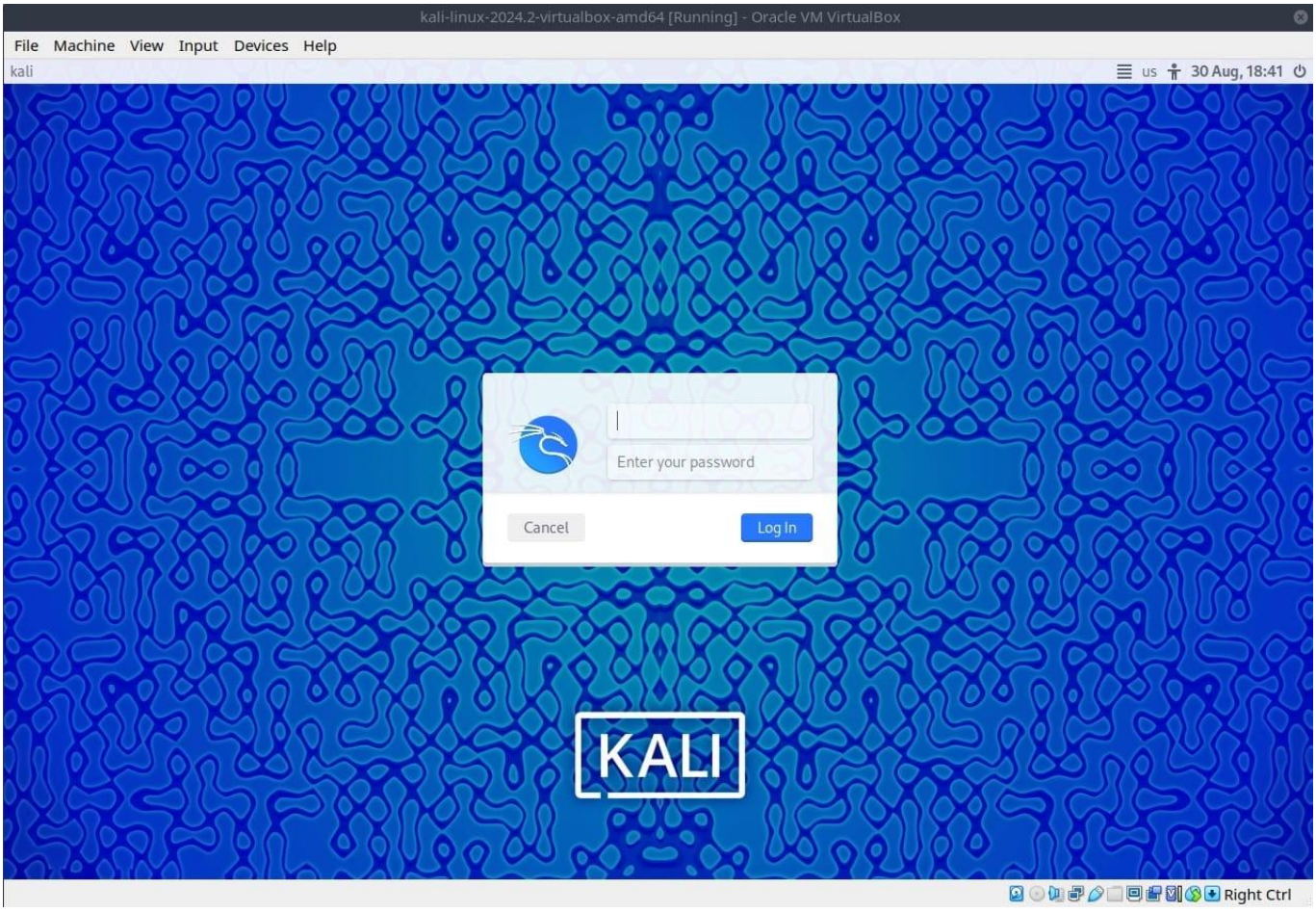
Step 2: Install Kali Linux

The second step is to install Kali Linux on the computer. Kali Linux is a Linux operating system.

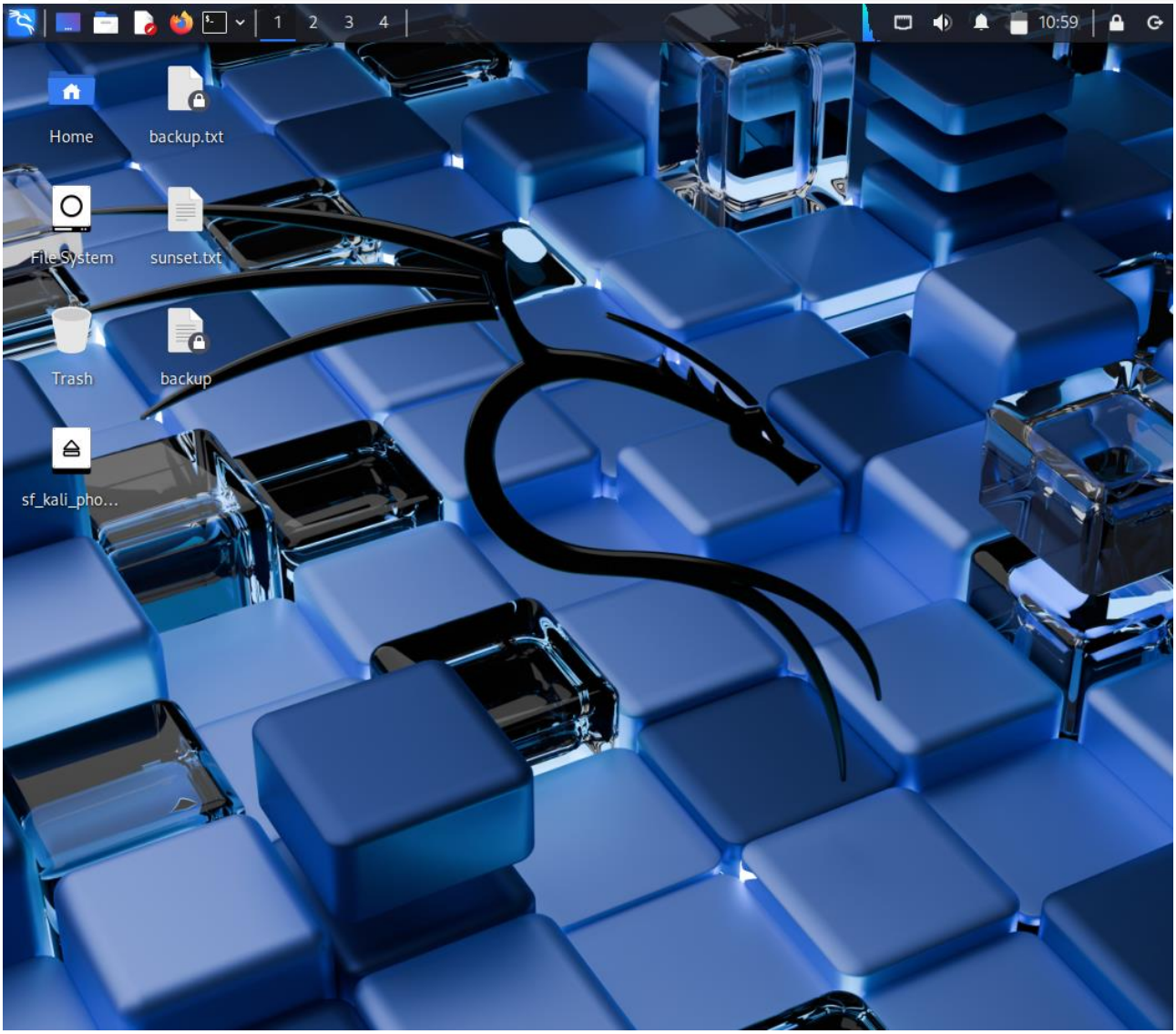
Steps:

1. Download the Kali Linux VirtualBox image from the official website.
2. Launch VirtualBox on the computer.
3. Click on *Import Appliance* in VirtualBox.
4. Choose the downloaded Kali Linux file.
5. Click on *Start* to launch Kali Linux.

- **Kali Linux login screen**



-
- **Kali Linux desktop screen**



Step 3: Download Metasploitable 3

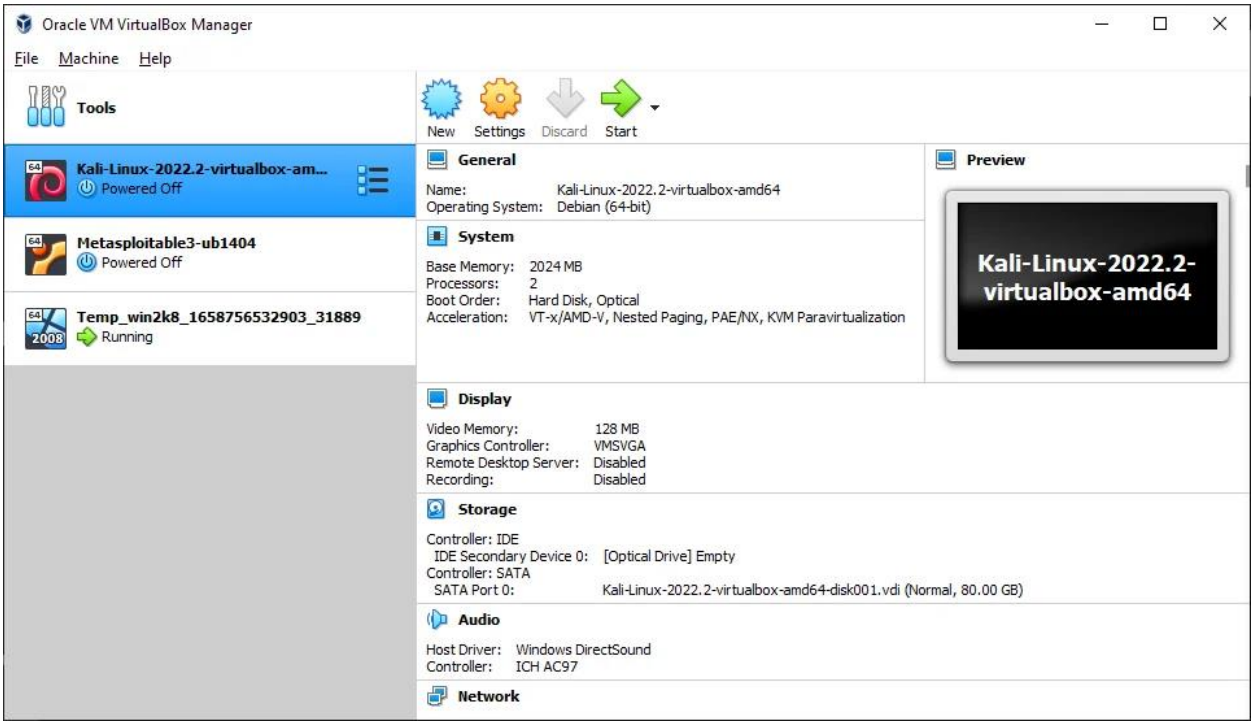
The third step is to download Metasploitable 3 on the computer. Metasploitable 3 is a deliberately vulnerable operating system.

Steps:

1. Download the Metasploitable 3 VM from the GitHub repository.

2. Extract the downloaded file.
3. Import the extracted file in VirtualBox.

- **Metasploitable 3 VM imported in VirtualBox**



- **Metasploitable 3 terminal screen running**

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:cd:dd:08
          inet addr:192.168.29.183  Bcast:192.168.29.255  Mask:255.255.255.0
          inet6 addr: 2405:201:c42a:f835:a00:27ff:fecd:dd08/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fecd:dd08/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:220 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:20039 (19.5 KB)  TX bytes:11037 (10.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:97 errors:0 dropped:0 overruns:0 frame:0
          TX packets:97 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21529 (21.0 KB)  TX bytes:21529 (21.0 KB)
```

Step 4: Configure Network

Both Kali Linux and Metasploitable must be on the *same network*.

Steps:

1. Open VirtualBox settings.
2. Go to *Network Settings*.
3. Select *Host-Only Adapter* or *Internal Network*.
4. Both virtual machines are started.

IP address in Metasploitable using:

Ifconfig

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:cd:dd:08
          inet addr:192.168.29.183  Bcast:192.168.29.255  Mask:255.255.255.0
          inet6 addr: 2405:201:c42a:f835:a00:27ff:fecd:dd08/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fecd:dd08/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:220 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:20039 (19.5 KB)  TX bytes:11037 (10.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:97 errors:0 dropped:0 overruns:0 frame:0
          TX packets:97 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21529 (21.0 KB)  TX bytes:21529 (21.0 KB)
```

- Metasploitable IP address in terminal

2. Vulnerability Scanning

Objective

The objective of vulnerability scanning is *to identify the security weaknesses in the Metasploitable system* by using automated scanning tools.

Tools Used

OpenVAS

OpenVAS is a *free vulnerability scanning tool* available in Kali Linux.

It scans the system and detects the security vulnerabilities present in the system. The security vulnerabilities detected by OpenVAS include:

- Outdated services
- Weak configurations
- Lack of patches

Nikto

Nikto is a *web server vulnerability scanning tool* that helps us detect security vulnerabilities in the web server.

It detects the security vulnerabilities present in the web server. The security vulnerabilities detected by the tool include:

- Dangerous files
- Weak configurations
- Lack of patches

Step 1: Start OpenVAS

To start OpenVAS:

The OpenVAS scanning tool needs to be started before scanning the system. To start OpenVAS, the following command is executed in Kali Linux:

sudo gvm-start

The *Greenbone Vulnerability Management (OpenVAS interface)* is started by the above command.

- **OpenVAS starting in the terminal**

```
root@kali: ~
File  Edit  View  Search  Terminal  Help
root@kali:~# openvas-setup
/var/lib/openvas/private/CA created
/var/lib/openvas/CA created

[i] This script synchronizes an NVT collection with the 'OpenVAS NVT Feed'.
[i] The 'OpenVAS NVT Feed' is provided by 'The OpenVAS Project'.
[i] Online information about this feed: 'http://www.openvas.org/openvas-nvt-feed.html'.
[i] NVT dir: /var/lib/openvas/plugins
[w] Could not determine feed version.
[i] rsync is not recommended for the initial sync. Falling back on http.
[i] Will use wget
[i] Using GNU wget: /usr/bin/wget
[i] Configured NVT http feed: http://www.openvas.org/openvas-nvt-feed-current.tar.bz2
[i] Downloading to: /tmp/openvas-nvt-sync.V3pYxSaYIL/openvas-feed-2016-04-28-22922.tar.bz2
--2016-04-28 16:31:41--  http://www.openvas.org/openvas-nvt-feed-current.tar.bz2
Resolving www.openvas.org (www.openvas.org)... 5.9.98.186
Connecting to www.openvas.org (www.openvas.org)|5.9.98.186|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 25475644 (24M) [application/x-bzip2]
Saving to: '/tmp/openvas-nvt-sync.V3pYxSaYIL/openvas-feed-2016-04-28-22922.tar.bz2'

s-nvt-sync.V3pYxSaYIL/openv  10%[===>                    ]   2.46M   557KB/s    eta 47s
 vt-sync.V3pYxSaYIL/openvas  11%[===>                    ]   2.75M   574KB/s    eta 47s
feed-2016-04-28-22922.tar.  34%[============>            ]   8.32M   821KB/s    eta 25s
```

www.hackingtutorials.org

Step 2: Access OpenVAS Web Interface

To access the OpenVAS web interface:

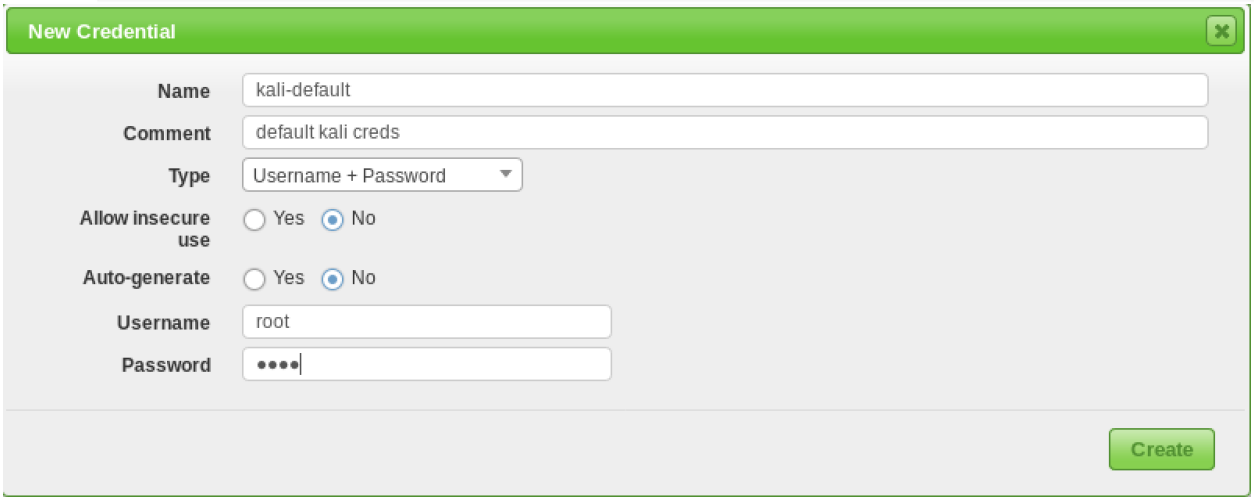
The OpenVAS web interface is accessed by the following steps:

- Open a web browser in Kali Linux.
- Enter the following URL in the web browser:

https://127.0.0.1:9392

- Enter your OpenVAS login credentials.

- **OpenVAS login page**
- **OpenVAS dashboard**



Step 3: Create Target

Steps:

1. Go to *Configuration → Targets*
2. Click on *New Target*
3. Enter the *Metasploitable IP address*
4. Save the target

- Target configuration page

Step 4: Start Vulnerability Scan

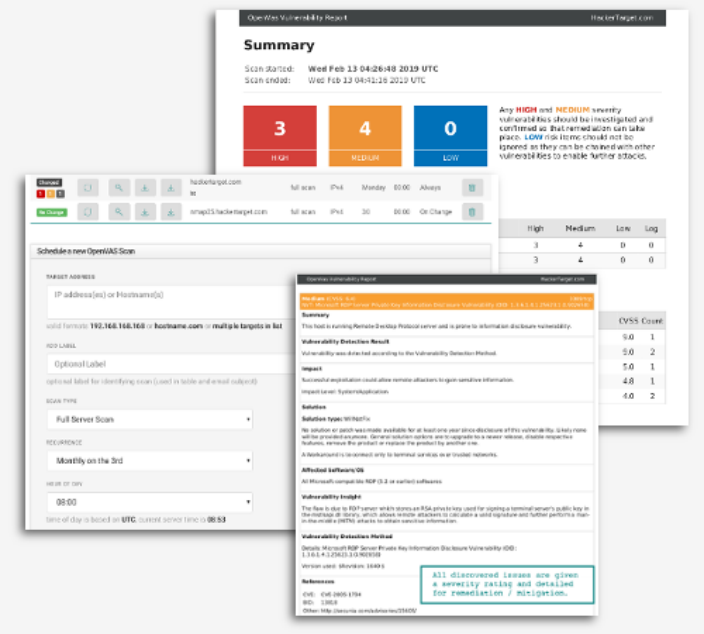
Steps:

1. Go to *Scans → Tasks*
2. Click on *New Task*

3. Select the created target
4. Start the scan

OpenVAS will now analyze the system and show us vulnerabilities if found.

- Scan running progress



Step 5: Analyze Results

Once the scan is complete, we can see detailed information about vulnerabilities found by OpenVAS:

- CVE ID
- CVSS Score
- Vulnerability description

- Recommended fixes

Example vulnerability:

Apache Tomcat outdated version

- Vulnerability report from OpenVAS

Step 6: Scan Web Server with Nikto

Nikto is a tool that can be used to scan a web server.

Run the following command:

nikto -h http://192.168.56.101

Nikto will now show us vulnerabilities found in the web server.

- Nikto scan output

```
┌──(kali㉿kali)-[~/nikto]
└─$ nikto -h google.com
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Multiple IPs found: 172.253.115.102, 172.253.115.113, 172.253.115.138, 172.253
.115.139, 172.253.115.100, 172.253.115.101, 2607:f8b0:4004:c08::66, 2607:f8b0:40
04:c08::8a, 2607:f8b0:4004:c08::8b, 2607:f8b0:4004:c08::65
+ Target IP:          172.253.115.102
+ Target Hostname:    google.com
+ Target Port:        80
+ Start Time:         2024-07-16 09:13:19 (GMT0)
---------------------------------------------------------------------------
+ Server: gws
+ /: The X-Content-Type-Options header is not set. This could allow the user age
nt to render the content of the site in a different fashion to the MIME type. Se
e: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-
content-type-header/
+ Root page / redirects to: http://www.google.com/
```

3. Document Findings

Objective

The objective of documenting findings is to record the discovered vulnerabilities during scanning.

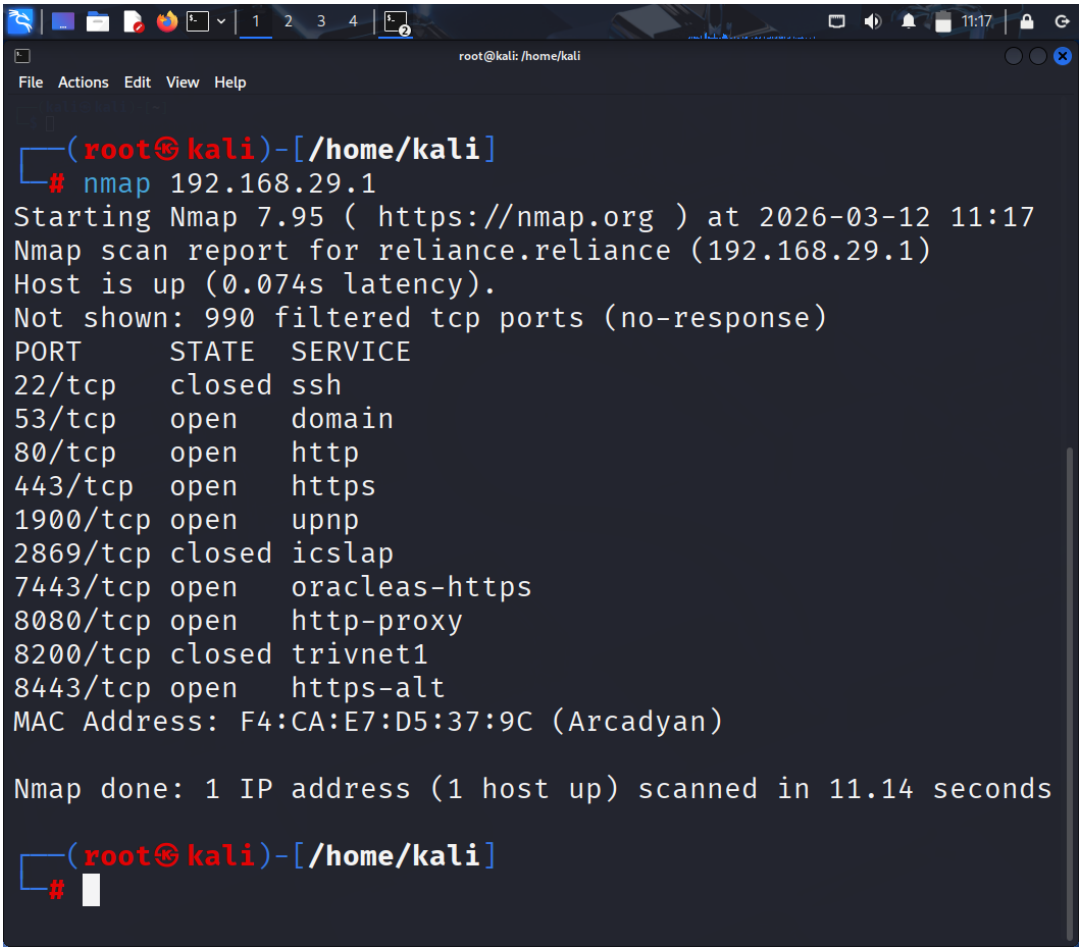
Tools Used

- Excel
- Google Sheets
- Screenshots

Step 1: Record Network Information

The network information should be documented as follows:

IP Address	Port	Service
192.168.29.1	80	TCP
192.168.29.1	22	TCP



- Nmap scan results

The Nmap scan command used may be as follows:

```
nmap -sV 192.168.29.1
```

Step 2: Record Vulnerabilities

The discovered vulnerabilities may be recorded in a table as shown below:

Vulnerability	CVE ID	Severity
Outdated Apache Server	CVE-2019-1234	High
Weak FTP Configuration	CVE-2020-5678	Medium

- Nmap scan results

Example Nmap command:

```
nmap -sV 192.168.29.1
```

4. Practice Risk Assessment

Objective

Risk assessment is important as it helps prioritize vulnerabilities according to their *severity and impact on the system*.

Step 1: Calculate CVSS Score

CVSS calculator is a tool that calculates the severity of a vulnerability.

CVSS has a range of 0-10 that represents different levels of severity as shown below:

Score	Severity
0–3.9	Low
4–6.9	Medium
7–8.9	High
9–10	Critical

SQL injection vulnerability has a *CVSS score of 9.0 which is critical*

- CVSS calculator result

Step 2: Create Risk Matrix

Create a 3x3 risk matrix as shown below:

- Using excel software

Likelihood	Impact	Risk
High	High	Critical
Medium	High	High
Low	Medium	Medium

- Risk matrix chart in Excel

5. Create Basic Security Report

Objective

The objective of creating a report is to present the findings of the security assessment clearly and professionally.

Report Structure

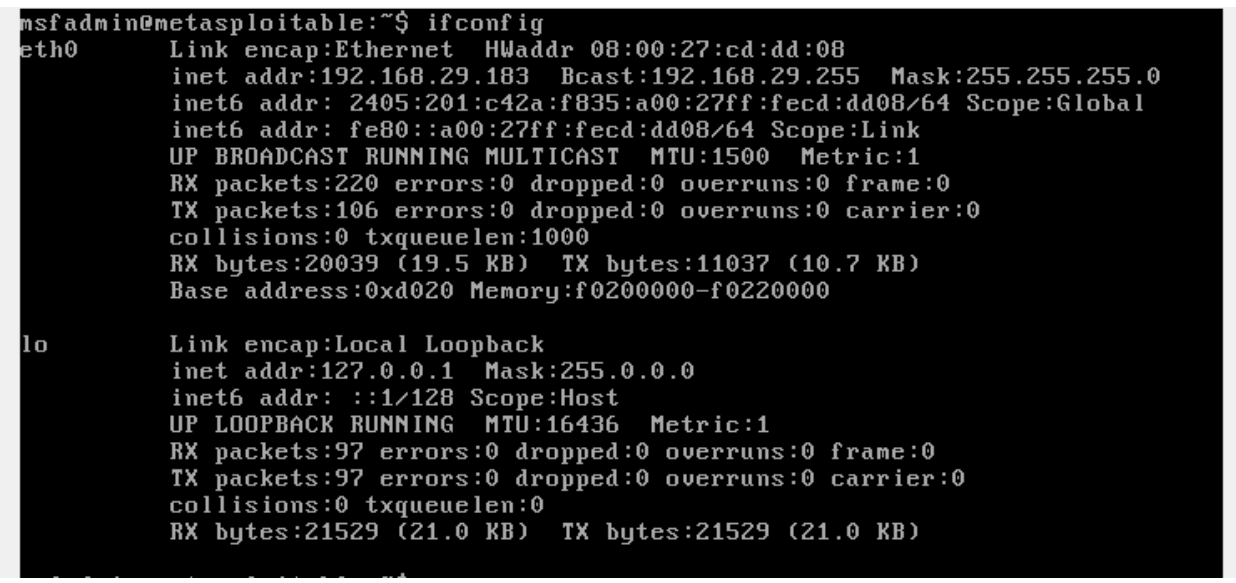
Your final report should contain the following sections:

1. Executive Summary

This section provides a *high-level overview of the security assessment*.

Example:

The security assessment revealed that the Metasploitable system contains various vulnerabilities. The Metasploitable system contains outdated versions of various types of software. This could allow an attacker to gain unauthorized access to the system.



```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:cd:dd:08
          inet addr:192.168.29.183  Bcast:192.168.29.255  Mask:255.255.255.0
          inet6 addr: 2405:201:c42a:f835:a00:27ff:fecd:dd08/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fecd:dd08/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:220 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:20039 (19.5 KB)  TX bytes:11037 (10.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:97 errors:0 dropped:0 overruns:0 frame:0
          TX packets:97 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21529 (21.0 KB)  TX bytes:21529 (21.0 KB)
```

- Summary dashboard of scan results

2. Technical Details

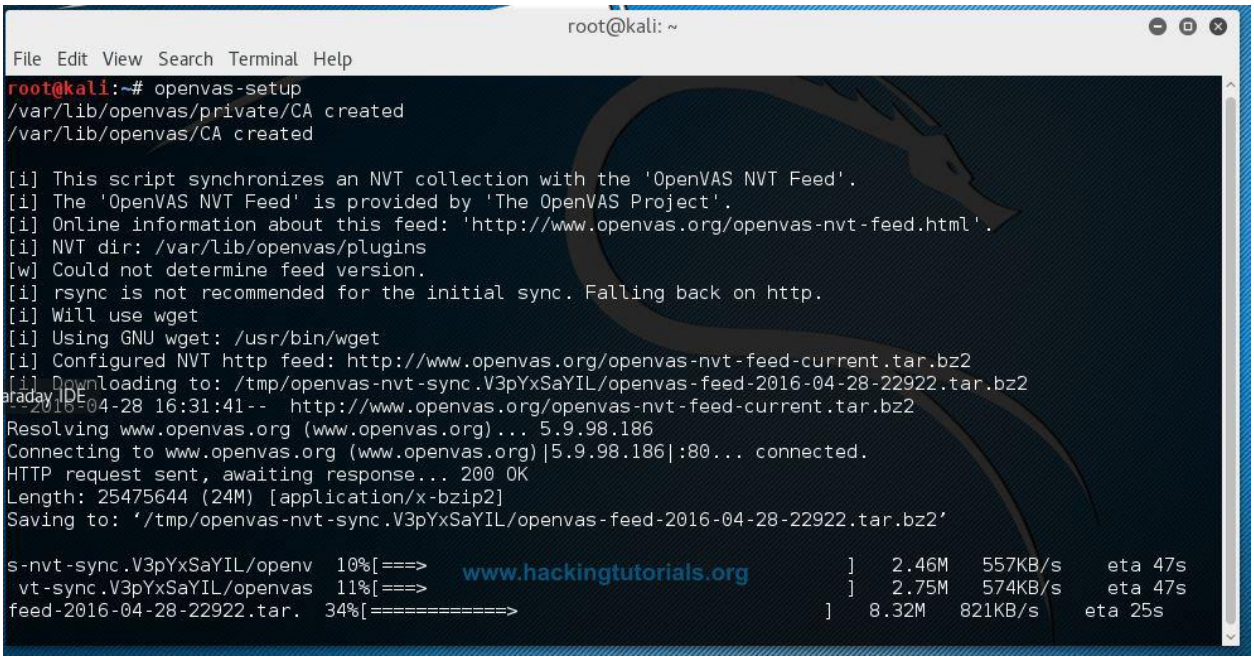
This section provides an explanation of the details of the vulnerability.

This section should contain the following details:

- IP address
- Vulnerability description
- CVSS score
- Screenshots of evidence

Example:

Vulnerability: Outdated Apache Server *CVSS Score:* 8.5 (High) *Impact:* Attackers may exploit the vulnerability to execute malicious code.



- OpenVAS vulnerability

3. Remediation

In this section, solutions for the vulnerabilities will be provided.

Examples:

Vulnerability	Solution
Outdated Apache	Update to latest version
Weak FTP configuration	Disable anonymous login

- Patch documentation or configuration fix

4. References

References used in the report will be provided in this section.

Examples:

- Kali Linux documentation
- OpenVAS documentation
- OWASP resources
- CVE database

Final Submission

Once the report is prepared, the following steps will be followed:

1. Compile all sections in a document.
2. Add screenshots where necessary.
3. Format the document properly.
4. Save the document in *PDF format*.
5. Submit the final *Security Assessment Report*.